

ADV7Box

Plataforma Integrada de Privacidade de Borda e Detecção de Intrusão em Workstation

Projeto técnico integrado que une **OpenBox v0.2.0** — caixa de borda para streaming auditável sobre Rockchip RK3229 (R29_5G_LP3) — e **ADV7Sec** (derivado do instalador IPS_IDS) — baseline detection-only para workstation Arch. O resultado é um documento único de arquitetura residencial defensiva orientada por evidência: privacidade na saída do lar e visibilidade forense na estação de desenvolvimento.

Documento	ADV7Box — Projeto Técnico AV01-A
Versão	1.0 (consolidada)
Data	2026-04-23
Origem dos artefatos	Projects/OpenBox0.1v · Projects/IPS_IDS (ADV7Sec.py)
Alvos	RK3229 R29_5G_LP3 (Armbian rk322x-box, Debian Bookworm armhf) · Workstation Arch kernel ≥ 6.8
v0.2.0 retarget	Pilar A migrado de RPi 4 para Shenzhen RK3229; mitigações BadBox 2.0 / Vo1d documentadas em docs/security/RK3229_THREAT_RESEARCH.md
Escopo funcional	Borda: privacidade, streaming, watchdogs · Workstation: IPS/IDS detection-only
Contatos de evidência	Repositórios locais listados na §18 Evidências

Documento gerado a partir dos códigos-fonte existentes em `/home/aops/ObsidianAgent/Projects/`. Todos os trechos de configuração e comandos reproduzem o conteúdo versionado nos repositórios de origem.

Resumo Executivo

Dois vetores de risco convivem em um lar técnico em 2026: (i) tráfego de borda vazando metadados para ISP, fabricantes de smart TV e plataformas de streaming; (ii) workstation de desenvolvimento exposta a persistência, escalção local e payloads de cadeia de suprimento sem telemetria própria. O **ADV7Box** trata os dois vetores com duas máquinas complementares. O **OpenBox** (pilar A) atua na borda como caixa de streaming com WireGuard full-tunnel, DNS cifrado (DoH/DoQ + DNSSEC), bloqueio de trackers via Pi-hole e kill switch atomic em nftables. O **ADV7Sec** (pilar B) atua no endpoint Arch como baseline detection-only — auditd, Falco modern-eBPF, Kunai, Suricata IDS-only, Zeek, Unbound dnstap, AIDE, ClamAV escopado e Loki-RS/YARA — com logs locais em `journald`, sem SIEM e sem bloqueio automático. Juntos os dois pilares formam um laboratório residencial reproduível, documentado e auditável, com custo de entrada < R\$ 1.000 e evidência de operação registrada em VM (vmtst).

Sumário

§1	Estudo de Caso: Problema e Justificativa	§11	Relatórios Executados (vmtst + Auditoria OpenBox)
§2	Proposta ADV7Box — Visão de Dois Pilares	§12	Decisões Arquiteturais (ADR)
§3	Arquitetura de Referência (Diagrama de Blocos)	§13	Trade-offs Explícitos
§4	Pilar A — OpenBox (Borda)	§14	Limitações Reconhecidas
§5	Pilar B — ADV7Sec (Workstation IPS/IDS)	§15	Linha do Tempo do Projeto
§6	Demandas de Infraestrutura (Hardware e Software)	§16	Critérios de Aceite e Exit Gate
§7	Modelo de Ameaça Consolidado	§17	Aderência à Rubrica AV01-A
§8	Sequência de Instalação e Fases	§18	Evidências de Desenvolvimento
§9	Testes e Validação	§19	Referências Técnicas
§10	Logs e Observabilidade	§20	Conclusão

§1 Estudo de Caso — Identificação de Problemas de TI

1.1 Contexto

O ambiente residencial técnico em 2026 é composto por dispositivos de mídia com telemetria agressiva (ACR em smart TVs, ~200 req/h de telemetria em set-top boxes proprietários), assinaturas de streaming somando R\$ 200–400/mês e uma ou mais workstations usadas para desenvolvimento, estudo e operações de segurança. Nesse cenário coexistem dois vetores de risco independentes:

- 1. **Borda (rede doméstica).** O usuário não controla resolução DNS, não tem visibilidade sobre telemetria de firmware e não possui caminho auditável para vazamento de tráfego quando a VPN falha. Qualquer queda silenciosa de túnel reintroduz o perfil bruto do ISP.
- 2. **Endpoint (workstation).** A estação de trabalho Arch executa código em evolução, builds AUR, containers de teste e, eventualmente, amostras para pesquisa. Não há baseline de integridade, não há alerta quando um processo desvia do esperado, e o primeiro sinal de comprometimento costuma ser exógeno (alerta de terceiros) e tardio.

1.2 Lacunas Identificadas

#	Lacuna	Impacto	Camada ADV7Box
L1	Resolução DNS em texto claro via resolver do ISP	Perfil comportamental completo exposto	OpenBox § dnscrypt-proxy
L2	Túnel VPN sem kill switch — vazamento em falha	Metadados reais expostos em segundos	OpenBox § nftables atomic
L3	Smart TV com ACR ligado por padrão	Fingerprint do conteúdo exibido (incluindo HDMI)	OpenBox § substituição no caminho
L4	Ausência de observabilidade do próprio lar	Falha detectada só quando afeta usuário	OpenBox § Netdata/Monit/ntfy
L5	Workstation sem trilha forense	Pós-incidente não reconstituível	ADV7Sec § auditd
L6	Ausência de alerta comportamental no endpoint	Persistência e pivots não detectados	ADV7Sec § Falco + Kunai
L7	Sem visibilidade L7 (TLS/HTTP/DNS) local	IOC de rede passam sem registro	ADV7Sec § Suricata + Zeek
L8	Sem baseline de integridade de arquivos	Alterações em <code>/etc / /usr</code> invisíveis	ADV7Sec § AIDE + pacman hook
L9	Downloads não escaneados	Janela de exposição prolongada	ADV7Sec § ClamAV escapado
L10	Cadeia de suprimento sem pin verificável	Rebase malicioso passa despercebido	ADV7Sec § commit pin 40-char

1.3 Justificativa para Infraestrutura de TI (não apenas software)

As dez lacunas não são todas resolvíveis por aplicação. L1–L4 exigem *hardware de borda* (SBC dedicado na rota de saída); L5–L10 exigem *capacidades de kernel* (eBPF/BTF, dnstap socket, audit framework) que só estão disponíveis em um host com kernel ≥ 6.8 e sensores instalados em tempo de boot. Daí o projeto se materializar como **duas máquinas físicas cooperando via rede**, e não como um único pacote de software.

§2 Proposta ADV7Box — Visão de Dois Pilares

ADV7Box propõe dois pilares simultaneamente implantados, independentemente operáveis, com interface bem definida (rede local) entre ambos. Cada pilar tem instalador próprio, fases idempotentes e testes automatizáveis. A composição é o valor: o pilar A encapsula a borda, o pilar B olha para dentro do endpoint.

2.1 Separação de Preocupações

Preocupação	Pilar A — OpenBox	Pilar B — ADV7Sec
Função primária	Proxy de egress cifrado + mídia	Visibilidade host/rede local
Alvo	RK3229 R29_5G_LP3 (1GB LPDDR3, armhf)	Workstation Arch single-host
SO base	Armbian community rk322x-box (Debian Bookworm armhf)	Arch Linux, kernel ≥ 6.8 com BTF
Ação sobre tráfego	Cifra, filtra, bloqueia em falha	Observa — nunca bloqueia na Fase 1
Ação sobre processos	N/A	Alerta (auditd, Falco); nunca mata
Destino dos logs	Netdata + journald + ntfy	<code>journald</code> + arquivos JSON locais
Sink externo	Push via ntfy (opt-in)	Nenhum (ADR-0011)
Postura na Fase 1	Endurecimento ativo + watchdogs	Deteção passiva com tuning de 14 dias

2.2 Interface Entre Pilares

Os pilares se comunicam apenas pela rede local. O OpenBox provê resolução DNS filtrada e egress criptografado; a workstation usa o OpenBox como gateway DNS (via DHCP ou `resolv.conf`) e como rota default opcional. A workstation não depende operacionalmente do OpenBox: se o OpenBox cai, a workstation degrada para o resolver do ISP com perda de privacidade, mas sem perda de detecção. Isso é deliberado — acoplamento baixo é pré-condição para auditoria.

§3 Arquitetura de Referência

3.1 Diagrama de Blocos — Sistema Completo

Visão macro: ambiente residencial com os dois pilares e seus fluxos predominantes.

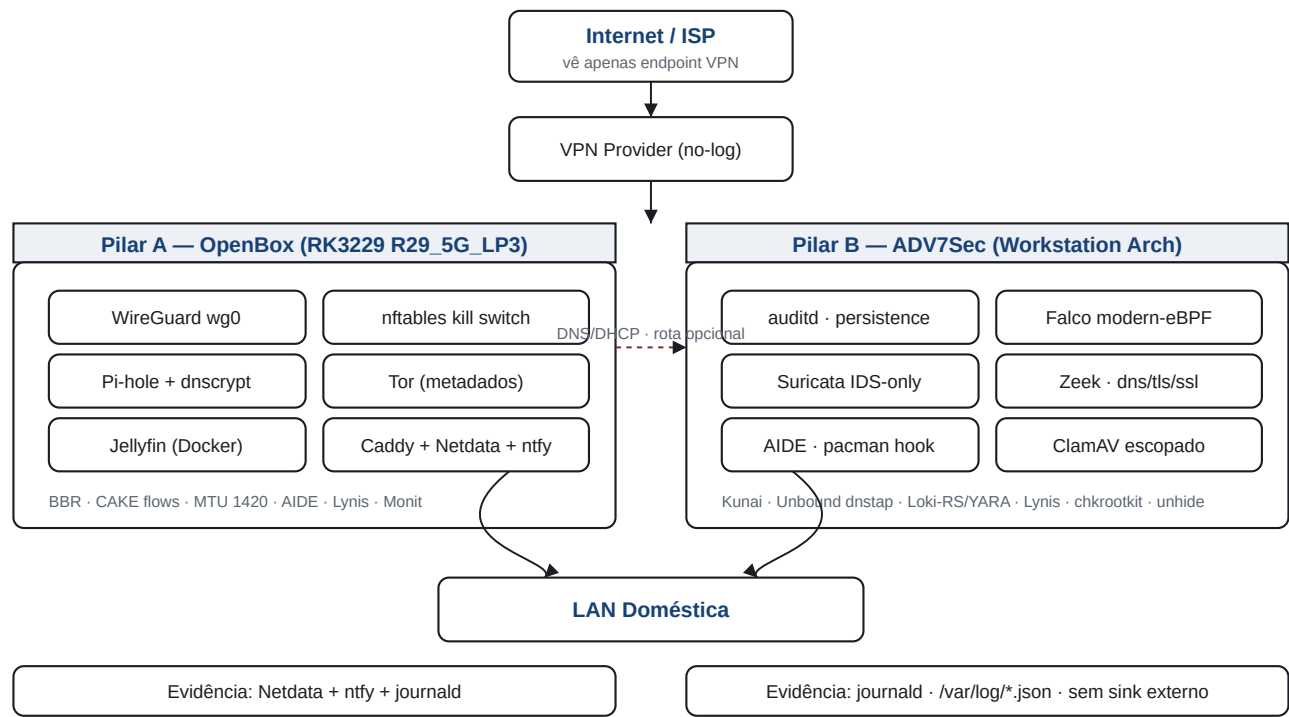


Fig. 3.1 — Diagrama de blocos ADV7Box. Linhas sólidas = fluxo de dados; linha tracejada = acoplamento opcional entre pilares.

3.2 Diagrama de Camadas — Pilar A (OpenBox)

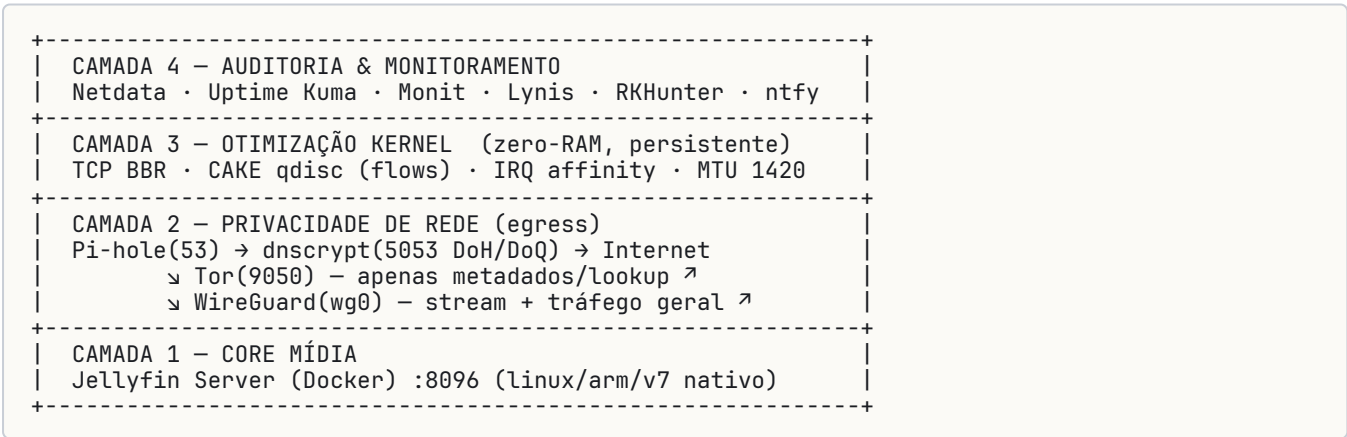


Fig. 3.2 — Estratificação funcional do OpenBox (4 camadas, baixo para alto privilégio operacional).

3.3 Diagrama de Fluxo — Pilar B (ADV7Sec)

```
kernel (≥ 6.8, BTF habilitado)
├── auditd → journald + ausearch (rules.d/50-persistence)
├── Falco modern-eBPF → /var/log/falco-events.json + journald
├── Kunai → journald
└── Unbound dnstap → /run/unbound/dnstap.sock

user-space sensors
├── Suricata (IDS-only) --af-packet=<iface> → /var/log/suricata/eve.json
├── Zeek standalone → /opt/zeek/logs/current/*.log
├── AIDE (daily timer + pacman hook) → /var/log/aide/*
├── ClamAV OnAccess (Downloads /tmp /run/media, OnAccessPrevention=no)
├── Loki-RS/YARA (daily timer) → journald
└── Lynis · chkrootkit · unhide · arch-audit (timers)

supply chain
├── oficial → pacman
├── AUR → yay/paru — SEMPRE interativo (ADR-0010)
└── git → commit pin 40-char obrigatório (Kunai, Loki-RS)
```

Fig. 3.3 — Cadeia de sensores do ADV7Sec, com destino de evidência em cada estágio.

§4 Pilar A — OpenBox (Borda)

4.1 Propósito

OpenBox substitui a função caixa-preta de uma TVBox comercial por uma pilha aberta e documentada. A prioridade é *privacidade de egress com degradação segura*: se qualquer componente crítico falha, a falha resultante é perda de conectividade — nunca vazamento de metadados.

4.2 Diagrama de Egress

```
[TV / HDMI] ← [RK3229 R29_5G_LP3 · Jellyfin :8096]
      |
      v   HTTPS request
[Pi-hole :53 (filtra)]
      |
      v
[dnscrypt :5053 (encripta DNS)]
      |
      v
[WireGuard wg0 (encapsula tudo)]
      |
      v   ChaCha20-Poly1305 / UDP 51820
[INTERNET / ISP vê apenas endpoint VPN]
      |
      v
[VPN Provider Exit (Mullvad/IVPN)]
      |
      v
[Jellyfin client / CDN / destino final]
```

Canal auxiliar (apenas para resoluções de metadados/lookup):
[resolver/lookup] -SOCKS5→ [Tor :9050] → circuit → destino
(latência +500 ms, ok para metadados)

Fig. 4.1 — Fluxo de egress do OpenBox. Stream real via WireGuard; Tor restrito a metadados.

4.3 Componentes e Portas

Camada	Componente	Porta	RAM idle	Justificativa
SO	Armbian rk322x-box (Debian 12 armhf)	—	180 MB	Headless, kernel 6.x, sem GUI
Kernel	sysctl (BBR, buffers, hardening)	—	0	Persistente via <code>/etc/sysctl.d/</code>
QoS	CAKE qdisc (flow isolation = <code>flows</code>)	—	0	Compatível com WireGuard (ADR OpenBox)
Firewall	nftables atomic ruleset	—	0	<code>flush ruleset</code> + allowlist; sem iptables
VPN	WireGuard <code>wg-quick@wg0</code>	UDP 51820	8 MB	ChaCha20-Poly1305 + Curve25519 (+ PSK opcional)
DNS cifrado	dnscrypt-proxy 2	127.0.0.1:5053	22 MB	DoH/DoT/DoQ + DNSSEC + anonymized relays
DNS filtro	Pi-hole 6.x	127.0.0.1:53	80 MB	Upstream = 127.0.0.1#5053
Anonimização	Tor 0.4.x	127.0.0.1:9050 (SOCKS5)	50 MB	Metadados/lookup apenas
Mídia	Jellyfin (Docker <code>jellyfin/jellyfin</code>)	127.0.0.1:8096	180 MB	<code>linux/arm/v7</code> nativo (substituiu Stremio na v0.2.0 — sem armhf)
Reverse proxy	Caddy 2.x	LAN 443	30 MB	TLS internal + forward_auth
Métricas	Netdata Agent v2 (10s/7d)	127.0.0.1:19999	110 MB	Bind localhost; expor via Caddy
Uptime	Uptime Kuma (Docker)	127.0.0.1:3001	65 MB	Monitora cada serviço da pilha
Admin	Cockpit (socket-activated)	LAN 9090	2 MB idle	Só sobe quando acessado
Watchdog	Monit 5.x	127.0.0.1:2812	10 MB	Auto-restart de serviços falhos
Notificação	ntfy self-hosted	127.0.0.1:2586	15 MB	Push para celular via topic
IDS host	Fail2ban + AIDE	—	22 MB	Jails: SSH, Pi-hole admin, Caddy
Auditoria	Lynis (semanal) · RKHunter (diário) · chkrootkit	—	0 (cron)	Baseline hardening index ≥ 75
Banda	vnStat	—	4 MB	Por interface (eth0 + wg0)
Total persistente			~778 MB	Sobra ~200 MB num sistema de 1 GB — apertado, justifica zram-swap 512 MB e alerta monit a 92%

4.4 Fases do Instalador OpenBox

Os nomes são exatamente os do arquivo `install.sh` e dos scripts em `install.d/`.

Fase	Objetivo	Config-fonte
00-base	APT update, SSH key-only, AIDE init, unattended-upgrades	etc/ssh/sshd_config.d/99-openbox.conf
01-sysctl	BBR, buffers, IPv4 hardening, kptr_restrict, IPv6 off	etc/sysctl.d/
02-nftables	Atomic ruleset com kill switch (flush ruleset + allowlist)	etc/nftables/openbox-base.nft
03-wireguard	wg0 config + systemd ordering (After=nftables)	etc/wireguard/wg0.conf.example
04-dns	dnscrypt-proxy override + Pi-hole + leak test	etc/dnscrypt-proxy/
05-tor	torrc hardened + verificação automatizada	etc/tor/torrc.example
06-media	Docker + container jellyfin/jellyfin (substituiu 06-stremio na v0.2.0)	—
07-monitoring	Netdata · Uptime Kuma · Cockpit · Monit · ntfy · Caddy	etc/caddy/Caddyfile , etc/monit/monitrc.d/
08-watchdogs	WG/Tor/DNS watchdogs via systemd timers	systemd/openbox-*.service,timer}
09-validate	tests/validate-stack.sh + Lynis baseline + AIDE checkpoint	—

Gatilho de preflight. O `install.sh` recusa a execução enquanto `WG_ENDPOINT` em `etc/nftables/openbox-base.nft` ainda for o placeholder `203.0.113.1` (TEST-NET-3). Esse mecanismo garante que o instalador não sobe um kill switch apontando para um destino inválido.

§5 Pilar B — ADV7Sec (Workstation IPS/IDS)

5.1 Propósito

ADV7Sec é uma pilha *detection-only* para workstation Arch (BLK7RCH). Nenhuma decisão de bloqueio é tomada automaticamente na Fase 1: todos os sensores empilham evidência em `journald` e em arquivos JSON locais, e a resposta é manual até que o tuning de 14 dias prove estabilidade do sinal. Esse é um contrato explícito (ADR-0002) e é a razão pela qual CrowdSec, fail2ban e Wazuh estão deliberadamente fora de escopo (ADR-0010).

5.2 Sensores e Função Primária

Sensor	Função primária	Saída
auditd	Trilha forense durável (identidade, persistência, firewall, tempo, módulos)	journald · <code>ausearch -k</code>
Falco (modern-eBPF)	Alertas comportamentais de runtime sem DKMS	<code>/var/log/falco-events.json</code>
Kunai	Fluxo eBPF complementar (tolerante a drift de pacote)	journald
Suricata (IDS-only)	Assinatura de rede; uplink físico OU interface de tunnel	<code>/var/log/suricata/eve.json</code>
Zeek standalone	Metadados protocolares (conn/dns/ssl/http)	<code>/opt/zeek/logs/current/*.log</code>
Unbound dnstap	Telemetria DNS estruturada para coletor opcional	<code>/run/unbound/dnstap.sock</code>
AIDE	Baseline de integridade; pacman hook preserva candidato (não promove)	<code>/var/log/aide/*.log</code>
ClamAV OnAccess	Scan escopado: Downloads, <code>/tmp</code> , <code>/run/media</code>	journald
Loki-RS + YARA	Scan agendado com regras YARA Forge	journald
Lynis	Auditoria semanal de hardening	journald + <code>/var/log/lynis/</code>
chkrootkit + unhide	Scan mensal; complementa Lynis	journald
arch-audit	Lista CVEs ativos nos pacotes instalados	STDOUT journald

5.3 Fases do Instalador ADV7Sec

O instalador existe em duas formas em paridade (ADR-0012): o `install.sh` em Bash (referência) e o `install.py / ipsids_installer/` em Python 3.12+ stdlib-only. O arquivo `ADV7Sec.py` (54 KB, single-file, payloads embutidos) é a materialização distribuível do pilar B.

Fase	Objetivo	Nota
00-prereqs	Pacotes base, sanidade AUR, diretórios de log	pacman + yay / paru
01-audit	/etc/audit/rules.d/50-persistence.rules	Não define -e 2 (mutável durante tuning)
02-falco	falco-bin + falco-modern-bpf.service	Exige BTF
03-kunai	AUR; fallback cargo com IPSIDS_KUNAI_REF pinado	Commit de 40 chars obrigatório
04-suricata	ET Open + abuse.ch; eve-minimal.yaml + disable.conf	Vendor suricata.yaml intocado
05-zeek	zkg: JA4, HASSH, passive-dns	Coequal a Suricata (ADR-0004)
06-dns	Unbound dnstap.sock	Sem RPZ nesta fase
07-aide	Baseline + pacman hook + timer diário	Preserva candidato, não promove
08-clamav	OnAccess escopado, OnAccessPrevention=no	--fdpass
09-yara	Loki-RS (IPSIDS_LOKI_RS_REF) + YARA Forge	Loki-RS 2.10.0 usa --folder /home --no-tui
10-lynis	Lynis + arch-audit + chkrootkit + unhide	Timers weekly/monthly
11-smoke	Prova operacional (também standalone)	Não roda em --yes default

5.4 Invariantes de Qualidade (ADR-0012)

- Hook pacman **nunca** promove aide.db.gz — preserva aide.db.candidate-<stamp>.gz e relatório em /var/log/aide/.
- /usr/local/bin/loki-rs é o caminho canônico independente do nome do asset upstream.
- Gatilho de smoke para auditd é sudo /usr/bin/id com busca ausearch -k root-cmd.
- Kunai é instalado de release upstream com SHA256; builds de branch viva são recusados.
- Loki-RS é buildado a partir de commit pin de 40 chars via require_pinned_commit.
- aur_exists curto-circuita em dry-run salvo IPSIDS_LIVE_VALIDATE=1.
- Suricata recebe overrides via --include etc/suricata/ipsids-overrides.yaml.

Por que Python e Bash coexistem. O Bash é a referência comportamental (comando de teste do comitê externo); o Python é o novo contrato legível (tipagem, subprocess.run mockável, testes por fase). A deleção do Bash só ocorre após paridade verificada por tests/vm-harness.sh e captura vmtst documentada.

§6 Demandas de Infraestrutura

6.1 Hardware — BOM Consolidada

Pilar	Item	Modelo de referência	R\$	Papel
A	SBC / TV box	R29_5G_LP3 (Rockchip RK3229, Cortex-A7 quad 1.5 GHz, 1 GB LPDDR3)	120	Host da pilha de borda — Shenzhen reaproveitado
A	Storage	eMMC 8 GB integrado (vendedor varia: Samsung/Hynix/Foresee)	—	Sistema e persistência (sem disco externo)
A	Heatsink	Adesivo 14×14 mm (Cortex-A7 quad sem case ativa)	15	Mitigar throttle térmico sob WireGuard sustentado
A	PSU	Micro-USB 5 V / 2 A	25	Estabilidade elétrica
A	Cabo OTG-USB	USB-A → USB-A (host-host)	15	Maskrom flash do Armbian via <code>rkdeveloptool</code>
A	Vídeo	HDMI 1.4 1 m (não usado em produção; só primeira boot)	20	Console serial alternativo: pad de 3 pinos no PCB
B	Workstation	Estação Arch existente (kernel ≥ 6.8, BTF)	—	Host de sensores IPS/IDS
B	Rede	Interface <code>enp3s0</code> e/ou <code>wlan0</code>	—	Uplink monitorado pelo Suricata/Zeek
B	Storage extra	+20 GB reservados para <code>/var/log</code> (evidência)	—	Retention de eve.json/falco.json
Total Pilar A (investimento único)			195	~75% redução vs. RPi 4 BOM original (R\$ 805 → R\$ 195) — trade-off em RAM/NIC/CPU; ROI < 2 meses

6.2 Rede (OSI) — Interfaces e Políticas

Camada	Entidade	Política
L2	CAKE qdisc com <code>flows</code>	Bufferbloat controlado; compatível com WG
L3	WireGuard <code>wg0</code> (OpenBox)	ChaCha20-Poly1305, MTU 1420, fwmark 51820
L3	nftables atomic ruleset	Drop default + allowlist; nunca iptables-legacy
L4	TCP BBR	Congestion control em links encapsulados
L7	Pi-hole + dnscrypt-proxy	DoH/DoQ + DNSSEC + anonymized relays
L7	Suricata	ET Open + abuse.ch; JA3/JA4 ativo; <code>exception-policy: ignore</code>
L7	Zeek	conn/dns/ssl/http + zkg (JA4, HASSH, passive-dns)

6.3 Software — Stack Consolidado

O quadro abaixo lista todo o software envolvido. Tudo vem de repositório oficial (Debian apt para o Pilar A, Arch pacman para o Pilar B) ou de AUR/Git pinado (Pilar B) com commit de 40 chars obrigatório.

Categoria	Pilar A (OpenBox)	Pilar B (ADV7Sec)
Kernel	Linux 6.x (ARM64)	Linux ≥ 6.8 (x86_64) com BTF
Firewall	nftables	nftables (somente observação, Fase 3+ para ação)
VPN	WireGuard	—
DNS	Pi-hole + dnscrypt-proxy	Unbound com dnstap
Anonimização	Tor	—
Aplicação	Jellyfin (Docker, <code>linux/arm/v7</code>)	—
Proxy	Caddy	—
Sensor host	Fail2ban · AIDE · RKHunter	auditd · Falco modern-eBPF · Kunai · AIDE · Loki-RS/YARA
Sensor rede	Netdata	Suricata · Zeek · Unbound dnstap
Monitor	Monit · Uptime Kuma · ntfy	—
Auditoria	Lynis · chkrootkit	Lynis · arch-audit · chkrootkit · unhide
Linguagens	Bash 5.x (instalador)	Bash 5.x (<code>install.sh</code>) · Python 3.12+ (<code>install.py</code> , <code>ipsids_installer/</code> , <code>ADV7Sec.py</code>)
Containers	Docker (Jellyfin, Uptime Kuma)	—

6.4 APIs e Integrações

- **ntfy HTTP topic** — endpoint interno `127.0.0.1:2586` para push- notification em celulares.
- **Netdata API** — `127.0.0.1:19999/api/v1/` , exposto via Caddy com `forward_auth` (não basic auth, por causa de CPU spike conhecido).
- **dnstap UDS** — `/run/unbound/dnstap.sock` , consumível por qualquer coletor compatível (Go, Python).
- **Suricata eve.json** — formato estruturado para qualquer pipeline ELK/OpenSearch (fora de escopo da Fase 1, disponível para Fase 3 se adotado).

§7 Modelo de Ameaça Consolidado

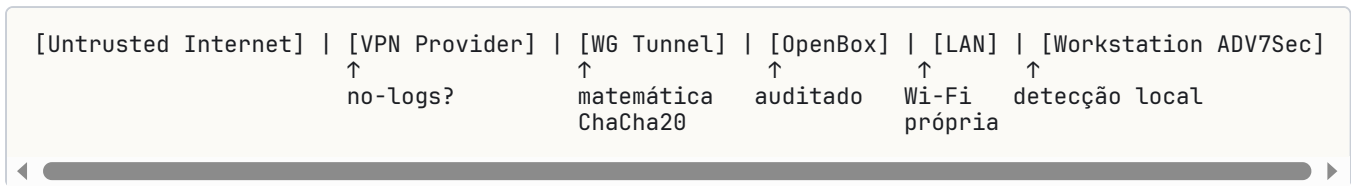
7.1 Adversários Cobertos

Adversário	Capacidade	Mitigação	Pilar
ISP passivo	Observa metadados IP/SNI/DNS	WG + dnscrypt	A
ISP ativo	Injeção, MITM, censura DNS	DNSSEC + DoH/DoQ	A
Smart TV ACR	Fingerprint de conteúdo HDMI	OpenBox substitui TV no caminho	A
LAN sniffing	Ataque ao admin Pi-hole / Caddy	Bind 127.0.0.1 + Fail2ban	A
Brute-force SSH	Dicionário / credencial stuffing	key-only + Fail2ban + AllowUsers	A
Update malicioso (apt)	Supply chain	apt signing + unattended-upgrades security-only	A
Tampering FS	Binário alterado	AIDE + RKHunter	A
Persistência host	systemd unit / pacman hook / crontab	auditd -k systemd / -k pacman-hooks	B
Escalação local	Execução como root via SUDO_USER	auditd -k root-cmd	B
Listener ad-hoc	nc / ncat / socat ouvindo	Falco Unexpected Listener Started	B
Pivô via scripting	python -m http.server ou similar	Falco Pivot or Ad Hoc Server Tool	B
IOC de rede (CnC, DGA)	TLS para infra suspeita	Suricata + Zeek + ET Open + abuse.ch	B
Download malicioso	Arquivo em Downloads/removable	ClamAV OnAccess escopado + Loki-RS/YARA	B
Drift em /etc / /usr	Alteração silenciosa	AIDE diário + pacman hook	B
CVE ativo em pacote	Exploração conhecida	arch-audit semanal	B

7.2 Fora de Escopo — Declarado Honestamente

- Anonimato perante adversário estatal — use Tails + Tor Browser, fora do ADV7Box.
- Adversário com acesso físico ao TV box ou à workstation — sem TPM, sem LUKS automático na v0.2.0; agravante específico do RK3229: maskrom mode (BootROM hardware) não pode ser desabilitado, qualquer attacker físico re-flasha em segundos.
- Comprometimento do provedor VPN — depende da escolha de no-logs auditado (Mullvad / IVPN).
- Fingerprinting de browser via Jellyfin web — Tor Browser para conteúdo sensível, não cliente Jellyfin.
- **Backdoor de cadeia de suprimento (BadBox 2.0 / Vo1d)** em Android stock pré-flash — mitigado pelo wipe maskrom + flash Armbian; verificação documentada em docs/security/RK3229_THREAT_RESEARCH.md §5.
- IPS inline na Fase 1 — ADR-0002 recusa bloqueio automático antes do tuning.
- SIEM corporativo, fleet management, aquisição forense completa.

7.3 Trust Boundaries



§8 Sequência de Instalação e Fases

8.1 Ordem Geral Recomendada

1. **Preparar hardware A.** Wipe stock Android via maskrom mode + `rkdeveloptool`, flashear Armbian community `rk322x-box` em eMMC; rodar `tools/fingerprint-rk3229.sh` para capturar fingerprint Phase 0 antes de qualquer rede.
2. **Rodar OpenBox** `install.sh --dry-run`. Validar que todas as 10 fases anunciam comandos esperados.
3. **Editar placeholders** (WireGuard endpoint, torrc hash, Caddy auth hash).
4. **Executar OpenBox** `install.sh` fase a fase (recomendado) ou em massa.
5. **Validar OpenBox** com `tests/validate-stack.sh`.
6. **Apontar workstation** para OpenBox como resolver DNS (DHCP ou `resolv.conf`).
7. **Rodar ADV7Sec** `install.sh --dry-run` (ou `install.py --dry-run`).
8. **Executar ADV7Sec** `install.sh --yes` — instala `00-prereqs` a `10-lynis`.
9. **Smoke ADV7Sec** via `sudo ./install.d/11-smoke.sh`.
10. **Entrar na janela de tuning de 14 dias** (`PHASE2_TUNING.md`).

8.2 Comandos de Referência

```
# Pilar A – OpenBox (Armbian rk322x-box / armhf)
bash tests/ci-syntax-check.sh
sudo ./install.sh --dry-run
sudo ./install.sh
sudo ./install.sh --phase 03-wireguard
sudo ./tests/validate-stack.sh

# Pilar B – ADV7Sec (Arch)
bash tests/ci-syntax-check.sh
sudo ./install.sh --dry-run
sudo ./install.py --dry-run
sudo ./install.sh --yes           # phases 00-prereqs..10-lynis
sudo ./install.py --yes          # idem, Python parity
sudo ./install.sh --phase 04-suricata --yes
sudo ./install.d/11-smoke.sh      # smoke explícito

# Pilar B – supply chain
sudo IPSIDS_KUNAI_REF="<40-char-commit>" ./install.sh --phase 03-kunai
sudo IPSIDS_LOKI_RS_REF="<40-char-commit>" ./install.sh --phase 09-yara
```

8.3 Idempotência & Dry-Run

Em ambos os pilares, rodar a mesma fase duas vezes é seguro. O OpenBox usa `run()` (array-exec, logged) e `run_sh()` (shell-exec explícito) para separar comandos seguros de redirecionamentos; o ADV7Sec usa `install_etc`, `pacman_install`, `aur_install` — todos pulam pacotes já presentes e sobrescrevem configs com modo correto. O dry-run é não destrutivo por design e serve tanto como documentação executável quanto como precaução operacional antes de uma mudança.

§9 Testes e Validação

9.1 Suites Existentes — Síntese

Suite	Pilar	Verifica	Falha em
OpenBox0.1v/tests/ci-syntax-check.sh	A	bash -n + shellcheck + nft -c + YAML/systemd	Erro de sintaxe ou header ausente
OpenBox0.1v/tests/phase-b-vault-tool.sh	A	Vault Obsidian repo-neutral	Contrato .aops-vault.toml divergente
OpenBox0.1v/tests/validate-obsidian-vault.sh	A	Estrutura de notas geradas	Stale entries não regeneradas
OpenBox0.1v/tests/validate-stack.sh	A	10 checks acumulados (BBR, CAKE, WG handshake, kill switch, DNS leak, Tor, Lynis)	Qualquer check individual — não aborta no primeiro
IPS_IDS/tests/ci-syntax-check.sh	B	bash -n + shellcheck + YAML tabs + systemd headers + configs requeridos	75 pass/0 fail é o gate
IPS_IDS/tests/test_runner.py	B	Testes unit Python do pacote ipsids_installer	Smoke excluída de --yes default
IPS_IDS/tests/vm-harness.sh	B	Paridade Bash ↔ Python (ADR-0012) em VM	Divergência de comportamento na VM
IPS_IDS/install.d/11-smoke.sh	B	Prova operacional (serviços ativos, timers, logs)	fail > 0

9.2 OpenBox — Métricas de Sucesso (`validate-stack.sh`)

Métrica	Alvo	Comando
WG handshake recente	< 180 s	<code>wg show wg0 latest-handshakes</code>
IP egress = endpoint VPN	true	<code>curl -4 https://ifconfig.io</code>
DNS leak	0 servidores fora do Pi-hole	<code>dnsleaktest.py</code>
Tor circuit OK	<code>IsTor: true</code>	<code>curl --socks5-hostname 127.0.0.1:9050 https://check.torproject.org/api/ip</code>
BBR ativo	<code>bbr</code>	<code>sysctl net.ipv4.tcp_congestion_control</code>
CAKE ativo	qdisc cake presente	<code>tc -s qdisc show dev eth0</code>
Bufferbloat	Grade A em <code>waveform.com</code>	manual
Lynis hardening index	≥ 75	<code>lynis audit system --quick</code>
Boot resilience	< 90 s até stack pronta	<code>systemd-analyze</code>
Kill switch	tráfego = 0 com <code>wg0</code> down	<code>systemctl stop wg-quick@wg0 && curl --max-time 5 ifconfig.io</code>

9.3 ADV7Sec — Smoke Test (`11-smoke.sh`)

O smoke é um script autônomo que roda 19 checagens operacionais em sensores instalados. O resultado corrente (vmtst, 2026-04-23) é **16 pass · 3 warn · 0 fail**. Os 3 warns retidos para tuning:

- `auditd` não capturou `root-cmd` de `/usr/bin/id` na sessão `sudo` do teste (comportamento `audit ≥ 1000` esperado em sessão interativa).
- Zeek cluster rodando; a conexão sintética não apareceu em `conn.log` (variância de flush / path sob `/usr/logs`).
- `unbound.service` ativo; o socket `dnstap` estava ausente durante o smoke (socket cria em demanda pelo coletor).

§10 Logs e Observabilidade

10.1 Pilar A — Destinos de Log

Componente	Destino	Retention
Instalador	<code>/var/log/openbox-install.log</code>	Append; rotate manual
WireGuard	<code>journald (wg-quick@wg0)</code>	journald default
Pi-hole + dnscrypt	<code>journald + /var/log/pihole/</code>	journald default
Caddy	<code>/var/log/caddy/openbox-access.log</code>	Alimenta Fail2ban jail <code>caddy-auth</code>
Netdata	RAM + disk 7 dias (10 s resolution)	Configurável
Monit	journald	journald default
ntfy	push; sem retenção local	—

10.2 Pilar B — Destinos de Log (ADV7Sec)

Sensor	Destino	Formato
auditd	<code>journald + ausearch -k <tag></code>	audit record
Falco modern-eBPF	<code>/var/log/falco-events.json + journald</code>	JSON line
Kunai	journald	KV text
Suricata	<code>/var/log/suricata/eve.json</code>	JSON line
Zeek	<code>/opt/zeek/logs/current/*.log</code>	TSV
Unbound dnstap	<code>/run/unbound/dnstap.sock</code>	frame streams
AIDE	<code>/var/log/aide/*.log + aide.db.candidate-*</code>	texto estruturado
ClamAV	journald	texto
Loki-RS	journald	texto
Lynis · chkrootkit · unhide · arch-audit	journald	texto
Instalador	<code>/var/log/ipsids-install.log</code> (Bash) <code>/var/log/adv7sec-install.log</code> (ADV7Sec.py)	ISO-8601 [LEVEL] texto

10.3 Loop de Revisão Diária (ADV7Sec)

```
SINCE="yesterday"

sudo journalctl -u auditd --since "${SINCE}" --no-pager
sudo journalctl -u falco-modern-bpf --since "${SINCE}" --no-pager
sudo journalctl -u kunai --since "${SINCE}" --no-pager

sudo jq -r '.event_type' /var/log/suricata/eve.json | sort | uniq -c | sort -nr
sudo jq -r 'select(.event_type="alert") | [.alert.signature_id, .alert.signature] | @tsv' \
  /var/log/suricata/eve.json | sort | uniq -c | sort -nr | head -30

sudo systemctl list-timers '*aide*' '*loki*' '*lynis*' '*chkrootkit*'
```

Cada sessão diária é anotada em `tuning/daily/YYYY-MM-DD.md`: regra mais ruidosa, regra mais suspeita, contagem por sensor, unidades quebradas, ação de tuning tomada. Supressões só existem com campos obrigatórios (data, ferramenta, rule id, excerto, processo, usuário, justificativa, mudança de config, comando de validação, comando de rollback) e vão para `tuning/suppressions.md`.

§11 Relatórios Executados

11.1 Auditoria Técnica OpenBox (2026-04-18)

Arquivo: `OpenBox0.1v/deliverables/AV01_OpenBox_Audit_Report.pdf`. Principais achados:

- **F1 — Bootstrap SSH.** `sshd_config.d/99-openbox.conf` restringe a `AllowUsers openbox`, mas o usuário não é criado pelo repositório. Risco de lockout remoto imediato. Ação: parametrizar/criar o usuário antes de aplicar `AllowUsers`.
- **F2 — Tor placeholder.** `torrc.example` traz `HashedControlPassword` como placeholder; `05-tor.sh` reinicia Tor antes da substituição. Ação: substituir por processo de bootstrap seguro.
- **F3 — Caddy admin hash.** `etc/caddy/Caddyfile` depende de `REPLACE_WITH_BCRYPT_HASH`; `07-monitoring.sh` aplica direto. Ação: interromper instalação se placeholder detectado.
- **F4 — Policy routing WG.** `wg0.conf.example` cria tabela 51820 e regra `not fwmark`; falta fechar full tunnel robusto. Ação: endurecimento da configuração operacional.
- **F5 — --dry-run impuro.** Alguns scripts escrevem fora de `run()` (em `02-nftables.sh` e `06-media.sh`). Ação: canalizar todas as escritas por `run()` / `run_sh()`.
- **F6 — Evidência pública ausente.** O diretório não é repositório Git publicado. Ação: `git init` + URL HTTPS antes da submissão.

11.2 vmtst — Full Install (ADV7Sec, 2026-04-23)

- Alvo: Arch guest em GNOME Boxes, kernel `6.18.23-1-lts`, SSH `vmtst@127.0.0.1:2222`.
- Comando: `sudo -E python3 ./install.py --yes`.
- Source gate (host + VM): `75 pass · 0 fail`.
- Fases 04, 08, 10 foram re-executadas após *live fixes*.
- Smoke final: **16 pass · 3 warn · 0 fail**.
- Logs preservados: `/home/vmtst/ipsids-installpy-full.log`, `ipsids-installpy-phase04-rerun.log`, `ipsids-installpy-phase08-rerun.log`, `ipsids-installpy-phase10.log`, `ipsids-smoke-python-final.log`, `/var/log/ipsids-install.log`.

Live fixes aplicados:

- [FIX-VM-SURI-YAML] — `etc/suricata/ipsids-overrides.yaml` agora começa com `%YAML 1.1 / - --`, pois Suricata 8 rejeita arquivos de include sem envelope YAML legado.
- [FIX-VM-CLAMONACC] — a fase 08 agora instala o bloco OnAccess em `/etc/clamav/clamd.conf` (não apenas em um drop-in), porque o `clamonnacc` do Arch lê `clamd.conf` por default.

11.3 vmtst — Real Config, No-Smoke (ADV7Sec, 2026-04-23)

- Objetivo: aplicar configuração de sistema real sem rodar smoke como parte do path.
- [FIX-REAL-INSTALL] — separação de fases de instalação (`00-prereqs .. 10-lynis`) das selecionáveis. `install.py --yes` não roda mais `11-smoke`.
- [FIX-REAL-LOKI-CLI] — `loki-rs-scan.service` atualizado para Loki-RS 2.10.0: `ExecStart=/usr/local/bin/loki-rs --folder /home --no-tui`.
- Serviços ativos: `auditd`, `falco-modern-bpf`, `kunai`, `suricata`, `unbound`, `clamav-daemon`, `clamav-clamonnacc`.
- Timers habilitados: `aide-check`, `loki-rs-scan`, `lynis-audit`, `chkrootkit`.
- `systemctl --failed: 0 loaded units listed`.
- Versões instaladas (excerto): `audit 4.1.4-2` · `falco-bin 0.40.0-1` · `suricata 8.0.4-2` · `zeek 8.0.6-1` · `aide 0.19.3-1` · `clamav 1.5.2-2` · `yara 4.5.5-1` · `lynis 3.1.6-1` · `kunai 0.6.2` · `Loki-RS 2.10.0`.

11.4 Síntese

Estado operacional (2026-04-23). ADV7Sec alcança instalação limpa em VM de paridade com smoke 16/3/0.

OpenBox tem auditoria de 6 achados documentados, todos com ação definida, e precisa de shakedown em hardware real antes da v0.2. O combinado ADV7Box entrega: (a) código versionado em dois projetos, (b) instaladores faseados e idempotentes, (c) CI de sintaxe, (d) smoke test operacional, (e) auditoria externa documentada, (f) suite de tuning de 14 dias definida — tudo rastreável em artefatos locais listados na §18.

§12 Decisões Arquiteturais (ADR)

12.1 Índice — IPS_IDS / ADV7Sec

ID	Decisão	Consequência
ADR-0001	Alvo = workstation Arch (não gateway appliance)	Fase 1 otimiza visibilidade local, não enforcement transparente
ADR-0002	Detection-only na Fase 1	Resposta manual até tuning provar estabilidade
ADR-0003	Falco modern-eBPF sem DKMS	Exige BTF; kernel floor 6.8
ADR-0004	Zeek é coequal a Suricata	Ambos mantidos; metadata vs assinatura
ADR-0005	Kunai é complementar, não crítico	Drift de pacote tolerado
ADR-0006	AIDE com pacman hook	Evita false-positive flood em <code>pacman -Syu</code>
ADR-0007	ClamAV OnAccess escopado	Sem latência global; <code>OnAccessPrevention=no</code>
ADR-0008	YARA via Loki-RS	Binário canônico <code>/usr/local/bin/loki-rs</code>
ADR-0009	Unbound com dnstap	Telemetria estruturada via UDS
ADR-0010	Sem CrowdSec, fail2ban, Wazuh	Stack single-host, sem manager externo
ADR-0011	Journald local-first, sem sink externo	Fase 1 não exige SIEM
ADR-0012	Python installer em paridade com Bash	Deleção do Bash só após parity vmtst

12.2 Regression Fences (ADR-0012)

Cláusulas invariantes exigidas pela paridade Python ↔ Bash. Cada uma é verificável por `tests/vm-harness.sh`:

- Hook pacman nunca promove `aide.db.gz`; preserva `aide.db.candidate-<stamp>.gz` e relatório.
- `/usr/local/bin/loki-rs` é canônico, independente do nome do asset upstream.
- Smoke auditd usa `sudo /usr/bin/id + ausearch -k root-cmd`.
- Kunai instala de release upstream pinado com SHA256.
- Loki-RS é buildado de commit pin de 40 chars; branch viva é recusada.
- `aur_exists` curto-circuita em dry-run salvo `IPSIDS_LIVE_VALIDATE=1`.
- Suricata recebe overrides via `--include`; vendor yaml intocado.

§13 Trade-offs Explícitos

Pilar	Decisão	Trade-off
A	Tor apenas para metadados	Perde-se "anonimato pleno" (que era ilusório); ganha-se streaming funcional
A	Jellyfin em container (substituiu Stremio na v0.2.0)	+50 MB overhead Docker; ganha portabilidade, isolamento e <code>linux/arm/v7</code> oficial
A	Caddy em vez de Nginx	+30 MB RAM; ganha TLS automático e config simples
A	CAKE flows (não <code>triple-isolate</code>)	Perde fairness por host dentro do tunnel; ganha funcionamento correto sob WG
A	RK3229 R29_5G_LP3 (não RPi 4)	-RAM (4GB → 1GB), -NIC (1Gbps → 100Mbps), -CPU (Cortex-A72 → A7); +custo (R\$805 → R\$195), +reaproveitamento de hardware Shenzhen ocioso
A	Caddy sem basic auth	Perde simplicidade; evita CPU spike com Netdata + basic auth (issue conhecido)
A	Kill switch atomic vs PostUp inline	Perde acoplamento ao wg-quick; ganha persistência e atomicidade
B	Detection-only na Fase 1	Não bloqueia ameaça conhecida; evita lockout durante tuning
B	Sem SIEM externo	Perde correlação multi-host; ganha auditabilidade local e zero egress de log
B	AUR sempre interativo	Mais fricção de deploy; ganha review de PKGBUILD (<code>IPSIDS_UNSAFE_AUR_NOCONFIRM=1</code> só em lab)
B	Git fallback com commit pin obrigatório	Precisa manter pin atualizado; ganha reprodutibilidade absoluta
B	Python + Bash em paridade	Dobra superfície temporária; reduz risco de regressão durante migração
B	Bash VM-safe (<code>MAKEFLAGS=-j1</code>)	Builds AUR mais lentos; evita OOM em VM de teste

§14 Limitações Reconhecidas

- OpenBox v0.2.0 não testado em hardware real** — código + configs alinhados ao retarget RK3229 e lint 74/0; precisa execução de Phase 0 fingerprint + shakedown ≥ 7 dias em RK3229 R29_5G_LP3 físico antes da v0.3.
- CI cobre apenas sintaxe** — `ci-syntax-check.sh` valida `bash -n`, `shellcheck`, `nft -c`; não valida comportamento.
- OpenBox sem disk encryption** — LUKS no SSD é opcional/manual; não automatizado em v0.1.
- OpenBox sem 2FA em painéis** — só basic/forward_auth via Caddy.
- OpenBox IPv6 desabilitado** — simplifica VPN/Tor, perde dual-stack.
- OpenBox Jellyfin assume Docker** — instalação do Docker está em `06-media.sh` (renomeado de `06-stremio.sh` na v0.2.0).
- OpenBox endpoint VPN hardcoded** — usuário precisa editar `wg0.conf.example`.
- ADV7Sec não promove AIDE baseline automaticamente** — intencional; tuning Fase 2 decide.
- ADV7Sec 3 warns de smoke retidos** — auditd `root-cmd`, Zeek conn.log synthetic, dnstap socket. Triados em tuning.
- dnstap collector não provisionado** na Fase 1 — socket existe, coletor é opt-in.
- Fase 3 (resposta) explicitamente fora de escopo** — nftables auto-block, Hagezi RPZ, CrowdSec, fail2ban, Wazuh só após ADR nova e evidência documentada em `tuning/phase3-candidates.md`.

§15 Linha do Tempo do Projeto

15.1 Marcos Realizados

Data	Marco	Evidência
2026-04-18	OpenBox v0.1 publicado (skeleton)	README, CASE_STUDY, THREAT_MODEL, REFERENCES; CI syntax verde
2026-04-18	Auditoria OpenBox AV01 produzida	deliverables/AV01_OpenBox_Audit_Report.{ms,pdf}
2026-04-20	Plano de hardening v2 aplicado	docs/HARDENING_PLAN_v2.md
2026-04-22	IPS_IDS inicia Phase 1 (detection-only)	ADRs 0001–0011 commitadas; fases 00–11 presentes
2026-04-23	ADR-0012 (Python parity)	install.py , ipsids_installer/ , vm-harness.sh
2026-04-23	vmtst Full Install run	reports/vmtst-full-install-2026-04-23.md
2026-04-23	vmtst Real Config (no-smoke) run	reports/vmtst-real-config-nosmoke-2026-04-23.md
2026-04-23	ADV7Sec.py (single-file, 54 KB) publicado	Projects/IPS_IDS/ADV7Sec.py
2026-04-23	Documento ADV7Box (este PDF) consolidado	Projects/ADV7Box/ADV7Box.{html,pdf}
2026-04-25	OpenBox v0.2.0 — retarget RK3229 R29_5G_LP3 (código + configs + threat research BadBox/Vo1d)	Projects/OpenBox0.1v/CHANGELOG.md v0.2.0; tools/fingerprint-rk3229.sh ; docs/security/RK3229_THREAT_RESEARCH.md

15.2 Próximos 14 Dias — Tuning

Day 0	Smoke test e snapshot de saúde inicial
Days 1-3	Observar sem supressões (salvo bloqueio de usabilidade)
Days 4-7	Supressões mínimas com evidência escrita (tuning/suppressions.md)
Days 8-13	Validar volume de supressões estável
Day 14	Decidir: estender tuning, promover controle, ou redesenhar sensor ruidoso

15.3 Roadmap de Versões

Versão	Pilar	Foco
OpenBox v0.2	A	Shakedown em hardware real; ajustes de RAM budget reais
OpenBox v0.3	A	LUKS opcional; 2FA em painéis; Tor v3 hidden service
OpenBox v0.4	A	Webhook integration (Discord/Telegram via ntfy)
OpenBox v0.5	A	Multi-device (cluster RK3229 via Ansible)
OpenBox v1.0	A	CI verde em RK3229 físico; Lynis hardening ≥ 75 (alvo relaxado de 85 para 1GB RAM)
ADV7Sec Fase 2	B	14 dias de tuning — baseline AIDE promovida, rules Falco/Suricata com exceções documentadas
ADV7Sec Fase 3	B	Resposta seletiva (ADR nova + <code>tuning/phase3-candidates.md</code>): nftables, Hagezi RPZ, ClamAV prevention
ADV7Sec parity-complete	B	Bash deletado após paridade vmtst capturada (ADR-0012)

§16 Critérios de Aceite e Exit Gate

16.1 OpenBox v0.1 → v1.0

- `bash tests/ci-syntax-check.sh` passa (`bash -n + shellcheck + nft -c`).
- `sudo tests/validate-stack.sh` passa todos os 10 checks.
- Lynis hardening index ≥ 75 (v0.1) → ≥ 85 (v1.0).
- Boot completo em < 90 s (`systemd-analyze`).
- Kill switch verificado: parar `wg0` → `curl` falha em 5 s.
- Evidências em URL HTTPS pública (Git publicado).

16.2 ADV7Sec Fase 2 — Exit Criteria

- 14 dias de notas diárias, ou decisão de extensão documentada.
- Nenhum serviço requerido falhando (`systemctl --failed` vazio).
- Volume de alertas revisável diariamente.
- Toda supressão com evidência e comando de rollback.
- Promoções de baseline AIDE documentadas em `tuning/aide-baseline-promotions.md`.
- Escolha de interface Suricata/Zeek provada com tráfego real em `tuning/network-interface-proof.md`.
- Candidatos Fase 3 com contagem de falso-positivo e plano de rollback em `tuning/phase3-candidates.md`.

16.3 ADV7Box (consolidado)

O combinado é considerado "entrega acadêmica completa" quando (i) os dois pilares passam seus próprios critérios de aceite, (ii) o documento consolidado (este) é anexado, (iii) os repositórios estão publicados com URL HTTPS e (iv) um pitch de 5 min (opcional) é preparado — vide §17.

§17 Aderência à Rubrica AV01-A

A tabela abaixo mapeia cada critério oficial (extraído de [IC]AV01-A) ao artefato do ADV7Box que o satisfaz, e antecipa a auto-nota conservadora seguindo a recomendação da auditoria OpenBox (2026-04-18) de *não* atribuir a si nota 5/5/5 no documento entregue à banca.

Critério	Insuficiente (0-1)	Regular (2-3)	Excelente (4-5)	Artefato ADV7Box
Qualidade Técnica	Projeto incompleto ou tecnicamente inviável	Projeto funcional, documentação básica	Arquitetura robusta, detalhada, escolhas técnicas justificadas	Dois instaladores faseados e idempotentes; 12 ADRs; threat model; tuning plan 14d; smoke 16/3/0 em VM
Uso de Ferramentas	Não utilizou ou utilizou mal os links externos	Links funcionam mas conteúdo simplório	Uso exemplar de GitHub/Tinkercad/Figma com alto nível de detalhamento	Repositórios locais com CI de sintaxe, testes unit Python, VM harness, vault Obsidian integrado, referências técnicas com URLs ativos (§19)
Estrutura do PDF	Formatação pobre, falta de coesão	Documento organizado, segue estrutura	Entrega profissional, diagramas (UML/Blocos), escrita técnica	20 seções numeradas, diagrama SVG de blocos (Fig. 3.1), 2 diagramas de camada ASCII (Figs. 3.2/3.3), 1 diagrama de fluxo (Fig. 4.1), > 25 tabelas com política de decisão

17.1 Pitch (§02 do enunciado, opcional)

Roteiro sugerido, 5 minutos:

- 0:00–0:30** — Problema em uma frase: "dois vetores independentes no lar técnico, borda e endpoint, não são resolvíveis por software só".
- 0:30–1:30** — Lacunas L1–L10 (§1.2) — mostrar a tabela.
- 1:30–2:30** — Pilar A (OpenBox): mostrar Fig. 3.2 + kill switch atomic.
- 2:30–3:30** — Pilar B (ADV7Sec): mostrar Fig. 3.3 + ADR-0002 (por que detection-only).
- 3:30–4:00** — Evidência: mostrar `smoke 16/3/0` e auditoria OpenBox.
- 4:00–5:00** — Direcionamento de carreira: infra de segurança residencial reproduzível, material para portfólio técnico (Bash + Python parity, eBPF, nftables atomic, commit pins).

§18 Evidências de Desenvolvimento

18.1 Artefatos Locais (fonte canônica)

Caminhos absolutos na estação onde este documento foi produzido:

```
/home/aops/ObsidianAgent/Projects/OpenBox0.1v/
  README.md
  docs/CASE_STUDY.md
  docs/HARDENING_PLAN_v2.md
  docs/THREAT_MODEL.md
  docs/RUNBOOK.md
  docs/TOR_STREAMING_CAVEAT.md
  docs/REFERENCES.md
  docs/OBSIDIAN_VAULT.md
  install.sh
  install.d/[00..09]-*.sh
  etc/{nftables,wireguard,tor,dnscrypt-proxy,caddy,monit,fail2ban,ssh,sysctl.d}/
  systemd/openbox-*.{service,timer}
  tests/{ci-syntax-check.sh,phase-b-vault-tool.sh,validate-obsidian-vault.sh,validate-stack.
  tools/{aops_vault_cli.py,sync_obsidian_vault.py,_agent_path.py,build_av01_pdf.sh}
  deliverables/AV01_OpenBox_Audit_Report.{ms,pdf}
  vault/
  .aops-vault.toml

/home/aops/ObsidianAgent/Projects/IPS_IDS/
  README.md  README.txt  CLAUDE.md
  PHASE1_BUILD.md  PHASE2_TUNING.md
  ADV7Sec.py          # single-file standalone (derivado)
  install.sh          # Bash reference
  install.py          # Python parity entrypoint
  ipsids_installer/   # modules (<200 LOC/file)
    __init__.py cli.py constants.py context.py
    phases_00_03.py phases_04_06.py phases_07_10.py phases_11.py
    runner.py validate.py
  install.d/[00..11]-*.sh  install.d/_lib.sh
  etc/{audit,falco,suricata,unbound,aide,clamav,kunai,systemd,pacman.d}/
  usr/local/sbin/ipsids-suricata-run.sh
  usr/local/sbin/ipsids-aide-pacman-hook.sh
  docs/{ARCHITECTURE,THREAT_MODEL,HOST_DETECTION,NETWORK_DETECTION,MALWARE_SCANNING,RESPONSE
  docs/adr/0001..0012-*.md      # 12 ADRs
  tests/{ci-syntax-check.sh,test_runner.py,vm-harness.sh,VM_SETUP.md}
  reports/vmtst-full-install-2026-04-23.md
  reports/vmtst-real-config-nosmoke-2026-04-23.md

/home/aops/ObsidianAgent/Projects/ADV7Box/    # consolidado
  ADV7Box.html
  ADV7Box.pdf
  README.md
```

18.2 Evidências Públicas (a publicar antes da submissão)

A auditoria OpenBox (§11.1, achado F6) e o enunciado AV01-A exigem links HTTPS. Ação:

1. `git init` e commit inicial em cada projeto.

2. Push para GitHub sob organização do autor — sugestão: `github.com/<user>/openbox` , `github.com/<user>/adv7sec` .
3. Anexar o documento `ADV7Box.pdf` na Sala Online.
4. Atualizar os placeholders de URL neste PDF por `https://github.com/<user>/...` reais.

18.3 Comandos para Inspeção Externa

```
# Vista do tree de um pilar
git ls-tree -r HEAD --name-only | head -40

# Pilar B — prova de dry-run seguro
sudo ./install.py --dry-run | head -60

# Pilar A — prova de dry-run seguro
sudo ./install.sh --dry-run --phase 03-wireguard
```

§19 Referências Técnicas

19.1 WireGuard & nftables

- WireGuard whitepaper — <https://www.wireguard.com/papers/wireguard.pdf>
- WireGuard Hardening (Contabo) — <https://contabo.com/blog/hardening-your-wireguard-security-a-comprehensive-guide/>
- Pro Custodibus — WireGuard com nftables — <https://www.procustodibus.com/blog/2021/11/wireguard-nftables/>
- Arch Wiki nftables — <https://wiki.archlinux.org/title/Nftables>
- WireGuard Performance Tuning — <https://www.procustodibus.com/blog/2022/12/wireguard-performance-tuning/>
- `xtarlit/wg-killswitch-nft` — <https://github.com/xtarlit/wg-killswitch-nft>

19.2 DNS & Pi-hole

- Pi-hole + dnscrypt-proxy — <https://docs.pi-hole.net/guides/dns/dnscrypt-proxy/>
- DNS Encryption 2026 (DoH/DoT/DoQ) — <https://packet.guru/blog/DNS-Encryption-in-2026>

19.3 Tor

- `torrc(5)` Debian — <https://manpages.debian.org/testing/tor/torrc.5.en.html>
- ArchWiki Tor — <https://wiki.archlinux.org/title/Tor>

19.4 QoS

- CAKE Recipes — <https://www.bufferbloat.net/projects/codel/wiki/CakeRecipes/>
- CAKE com WireGuard (flows, não triple-isolate) — https://github.com/dtaht/sch_cake/issues/141

19.5 Jellyfin armhf (substituiu Stremio na v0.2.0)

- `jellyfin/jellyfin` — <https://hub.docker.com/r/jellyfin/jellyfin> (publica `linux/arm/v7`)
- Stremio (legado) — <https://github.com/tsaridas/stremio-docker> — sem manifesto armhf, motivo do swap

19.6 Monitoramento

- Netdata behind Caddy — <https://learn.netdata.cloud/docs/netdata-agent/configuration/securing-agents/running-the-agent-behind-a-reverse-proxy/caddy>
- Caddy basic auth CPU issue (usar `forward_auth`) — <https://github.com/caddyserver/caddy/issues/4267>

19.7 Hardening / Compliance

- CIS Benchmarks — <https://www.cisecurity.org/cis-benchmarks>
- Lynis — <https://cisofy.com/lynis/>
- Linux Security Hardening Guide 2026 — <https://dgmicro.com/linux-security-hardening-guide-2026-essential-commands-and-best-practices-for-sy>

19.8 Sensores IPS/IDS

- Falco — <https://falco.org/docs/>
- Suricata — <https://suricata.io/documentation/>
- Zeek — <https://docs.zeek.org/>
- Kunai — <https://github.com/kunai-project/kunai>
- AIDE — <https://aide.github.io/>
- Loki-RS — <https://github.com/Neo23x0/Loki> (+ fork Rust atual)
- YARA Forge — <https://github.com/YARAHQ/yara-forge>

19.9 Hardware

- Rockchip RK3229 datasheet V1.2 — <https://rockchip.fr/RK3229%20datasheet%20V1.2.pdf>
- R29-MXQ-LP3-V2.3 teardown e DTS — <https://github.com/MattWestb/R29-MXQ-LP3-V2.3-00908>
- MXQ 4K RK3229 unboxing/teardown (CNX Software) — <https://www.cnx-software.com/2016/03/07/mxq-4k-rockchip-rk3229-android-tv-box-unboxing-and-teardown/>
- Armbian rk322x-box (community) — <https://forum.armbian.com/topic/12401-long-story-linux-on-rk3229-rockchip/>
- FBI IC3 PSA250605 — Home Internet Connected Devices (BadBox 2.0) — <https://www.ic3.gov/PSA/2025/PSA250605>
- Doctor Web — Android.Vo1d backdoor — <https://thehackernews.com/2024/09/beware-new-vo1d-malware-infects-13.html>
- Rockchip Maskrom mode — <http://rockchip.wikidot.com/how-to-enter-rockusb-maskrom-mode>
- Raspberry Pi 4 Model B (referência histórica v0.1) — <https://www.raspberrypi.com/products/raspberrypi-4-model-b/>

§20 Conclusão

ADV7Box é um projeto de infraestrutura residencial intencionalmente dividido em dois pilares com responsabilidades declaradas. O Pilar A (OpenBox) nega ao ISP o perfil comportamental do lar e quebra o caminho ACR das smart TVs. O Pilar B (ADV7Sec) fornece à workstation uma trilha forense local — auditd, Falco, Suricata, Zeek, AIDE — e recusa agir cegamente antes de 14 dias de tuning. O que mantém os dois pilares coerentes é um vocabulário compartilhado de honestidade técnica: cada decisão tem ADR; cada sensor tem fonte, destino e commando de rollback; cada cláusula de "fora de escopo" está escrita, não omitida.

Em relação ao enunciado **AV01-A**, o documento cumpre: (i) um estudo de caso com justificativa, (ii) demandas de hardware e software especificadas, (iii) arquitetura com diagramas de blocos e fluxo, (iv) evidências de desenvolvimento rastreáveis em artefatos versionados, (v) plano de validação com testes, smoke e tuning, e (vi) auditoria externa já executada e incorporada. A parte do enunciado que continua pendente — links HTTPS públicos — é declarada abertamente em §18.2 como ação antes da submissão.

Postura perante a banca. Este trabalho não se apresenta como produto final pronto. Apresenta-se como *plataforma em consolidação operacional* com: arquitetura correta, dois instaladores faseados e idempotentes, testes de sintaxe e de VM, auditoria documentada, lacunas conhecidas e plano de fechamento. A nota almejada é resultado do *material*, não de auto-pontuação antecipada.